

Revised Traceability Matrix with OWASP-Informed Test Coverage

Project: RoomRadar QC

Purpose

This document connects RoomRadar Qs user discovery findings, stakeholder requirements, functional requirements, use cases, test cases, and test results.

The purpose of this traceability matrix is to show that the project requirements were derived from user discovery interviews and that each major requirement is connected to one or more test cases.

This document also includes OWASP-informed web application security testing to address authentication, access control, input handling, deployment configuration, and sensitive data protection.

1. Traceability Approach

The traceability chain used in this document is:

User Discovery Interview Finding



Stakeholder Requirement



Functional / Security / Architecture Requirement



Use Case



Test Case



Actual Test Result

This structure helps show how the project moved from user needs to system requirements and then to QA testing.

2. Requirement ID Reference

Stakeholder Requirements

ID	Stakeholder Requirement
SR-1	Students need a faster way to find rooms that may be usable between classes.
SR-2	Students need to search by day and time.
SR-3	Students need to filter by building/location.
SR-4	Students need to know how long a room may remain usable.
SR-5	Students need a quick and simple interface that works on phone or laptop.
SR-6	Students need a dedicated interface because raw schedule data is not easy to find or use.
SR-7	Admin users need a controlled way to upload semester schedule data.
SR-8	Users need to understand that results are schedule-based suggestions, not guaranteed live availability.
SR-9	Admin features must be protected from unauthenticated users.
SR-10	Future versions should consider live occupancy, check-ins, reservations, room pictures, notifications, and room type details.

Main Functional Requirements

ID	Functional Requirement
FR-1	The system shall provide a room search page with day, start time, end time, and building inputs.
FR-2	The system shall require users to select day, start time, and end time before searching.
FR-3	The system shall reject searches where start time is greater than or equal to end time.
FR-4	The frontend shall send room search requests to the backend API.
FR-5	The backend shall return rooms without scheduled class conflicts for the selected day and time.

FR-6	The system shall allow users to filter search results by building.
FR-7	The system shall display results in readable room cards.
FR-8	Each room result shall show the room code and building.
FR-9	The system shall provide a Room Details page showing scheduled classes for a selected room.
FR-10	The Room Details page shall display class time, course name, and instructor when available.
FR-11	The system shall provide an Admin Login page.
FR-12	The system shall allow an authenticated admin to upload a semester CSV file.
FR-13	The backend shall reject CSV uploads with missing or invalid authorization tokens.
FR-14	The backend shall parse uploaded CSV data and insert semester, room, and schedule records into MySQL.
FR-15	The backend shall avoid creating duplicate room records during CSV upload.
FR-16	The frontend shall display a disclaimer explaining that results are schedule-based suggestions.
FR-17	The system shall support local and deployed environments using environment-based API URLs.
FR-18	The system shall exclude online and non-physical class locations from room search results.

Security Requirements

ID	Security Requirement
SEC-1	Admin upload requests shall include an Authorization header with a Firebase bearer token.
SEC-2	The backend shall verify the Firebase ID token before processing CSV uploads.
SEC-3	Missing or invalid tokens shall return 401 Unauthorized.
SEC-4	Database credentials shall be stored in environment variables.
SEC-5	Firebase service account credentials shall not be committed to GitHub.
SEC-6	Backend SQL queries shall use parameterized values for user-provided input.
SEC-7	CORS shall allow expected frontend origins to call the backend API.
SEC-8	Future versions should verify that an authenticated user is specifically an approved admin.

3. Use Case Reference

Use Case ID	Use Case
UC-1	Search for Suggested Rooms
UC-2	View Room Schedule Details
UC-3	Admin Login
UC-4	Upload Semester Schedule Data
UC-5	Understand Result Limitations

4. Main Traceability Matrix

Discovery Finding	Stakeholder Requirement	Functional / Security Requirement	Use Case	Test Case	Actual Result
Students often struggle to find quiet or empty spaces on campus.	SR-1	FR-1, FR-5	UC-1	TC-1 Search with valid day/time/building	Pass
Students manually walk around buildings checking rooms.	SR-1	FR-1, FR-4, FR-5	UC-1	TC-2 Search returns room suggestions from backend	Pass
Some students said searching manually can take 30 to 40 minutes.	SR-1	FR-1, FR-5, NFR-1	UC-1	TC-3 Room search completes within expected response time	Pass
Students want a website or app to show rooms that may be open.	SR-1, SR-6	FR-1, FR-7, FR-8	UC-1	TC-4 Results display in readable room cards	Pass
Students want to search current and future times.	SR-2	FR-1, FR-5	UC-1	TC-5 Search works with selected day and time interval	Pass
Students want to filter by building or location.	SR-3	FR-6	UC-1	TC-6 Building filter returns matching room results	Pass

Students want to know how long a room may remain usable.	SR-4	FR-9, FR-10	UC-2	TC-7 View Room Schedule displays class times	Pass
Students want a quick interface on phone or laptop.	SR-5	FR-1, FR-7, NFR-2	UC-1	TC-8 Search page is usable and readable	Pass
Students were not aware of raw course schedule CSV data.	SR-6, SR-7	FR-12, FR-14	UC-4	TC-9 Admin can upload semester CSV instead of users reading raw file	Pass
Admin users need a controlled way to update semester data.	SR-7	FR-11, FR-12, FR-14	UC-3, UC-4	TC-10 Authenticated admin can upload CSV	Pass
Admin features must be protected.	SR-9	FR-13, SEC-1, SEC-2, SEC-3	UC-3, UC-4	TC-11 Upload without token is rejected	Pass
Users need to understand results are not guaranteed live availability.	SR-8	FR-16	UC-5	TC-12 Disclaimer is shown to users	Pass
Some students suggested live occupancy, check-ins, and reservations.	SR-10	Future requirement	Future use case	TC-13 Future feature noted in limitations/future work	Pass
System needs environment-based local/deployed communication.	Project deployment need	FR-17, SEC-7	UC-1, UC-4	TC-14 Vercel frontend calls deployed backend URL	Pass
System should exclude online/non-physical classes.	SR-1, SR-8	FR-18	UC-1	TC-15 Online/non-physical class locations are excluded from room data	Pass

5. Test Case Details

Test Case ID	Related Requirement(s)	Test Description	Expected Result	Actual Result	Status
TC-1	FR-1, FR-5	Search using a valid day, start time, end time, and building.	System returns room suggestions.	System returned room suggestions.	Pass
TC-2	FR-4, FR-5	Confirm frontend sends search request to backend API.	Backend receives request and returns JSON.	Backend returned JSON response.	Pass
TC-3	NFR-1	Observe typical room search response time.	Results should load within expected time when backend/database are online.	Results loaded successfully during testing.	Pass
TC-4	FR-7, FR-8	Check room result card display.	Each result shows readable room/building information.	Room cards displayed room code and building.	Pass
TC-5	FR-1, FR-5	Search for a selected day and time interval.	Backend filters rooms by scheduled class conflicts.	Results reflected selected day/time search.	Pass
TC-6	FR-6	Search using a specific building filter.	Results only show matching building rooms.	Building filter worked as expected.	Pass
TC-7	FR-9, FR-10	Click View Room Schedule for a room.	Room Details page displays schedule records.	Room schedule displayed class time, course, and instructor when available.	Pass
TC-8	NFR-2	View search page on normal browser size and smaller screen.	Page remains usable and readable.	Page remained usable during testing.	Pass
TC-9	FR-12, FR-14	Upload semester CSV as authenticated admin.	CSV data is processed and inserted into database.	Upload workflow processed semester data.	Pass

TC-10	FR-11, FR-12	Log in as admin and access admin dashboard.	Authenticated admin reaches dashboard.	Admin dashboard was accessible after login.	Pass
TC-11	FR-13, SEC-1, SEC-2, SEC-3	Attempt CSV upload without valid token.	Backend rejects request.	Unauthorized upload was rejected.	Pass
TC-12	FR-16	Check for schedule-based availability disclaimer.	Disclaimer is visible to users.	Disclaimer was included in the UI/ documentation.	Pass
TC-13	SR-10	Check that future features from interviews are documented.	Future features are listed in limitations/future work.	Live occupancy/ check-in/ reservation ideas were documented as future improvements.	Pass
TC-14	FR-17, SEC-7	Confirm deployed frontend uses backend API base URL.	Vercel frontend calls deployed backend.	Frontend was updated to use environment-based backend URL.	Pass
TC-15	FR-18	Confirm non-physical/online class records are not treated as available physical rooms.	Online/non-physical locations are excluded.	Non-physical locations were excluded from room data handling.	Pass

6. OWASP-Informed Security Test Coverage

RoomRadar QC is a web application, so the test plan includes security checks inspired by common OWASP web application risk areas. These are not a full professional penetration test, but they connect OWASP concepts to the system's requirements and test cases.

OWASP Area	Related Requirement(s)	Security Concern	Test Case	Expected Result	Actual Result	Status
Broken Access Control	SEC-1, SEC-2, SEC-3	A non-admin or unauthenticated	TC-SEC-1 Attempt	Backend rejects	Request was rejected.	Pass

		user should not upload semester data.	CSV upload without token.	request.		
Identification and Authentication Failures	SEC-1, SEC-2, SEC-3	Invalid Firebase tokens should not allow admin actions.	TC-SEC-2 Submit upload with missing/ invalid bearer token.	Backend returns unauthorized response.	Unauthorized request was rejected.	Pas
Injection	SEC-6	Search inputs should not be directly concatenated into SQL queries.	TC-SEC-3 Review backend query handling for user search values.	Backend uses parameterized SQL values.	Parameterized query values were used.	Pas
Security Misconfiguration	SEC-4, SEC-5, SEC-7	Secrets and origins must be configured safely for deployment.	TC-SEC-4 Confirm credentials are not committed and CORS is configured for expected origins.	Secrets are outside GitHub; allowed origins are configured.	Environment variables and CORS settings were used.	Pas
Sensitive Data Exposure	SEC-4, SEC-5	Database passwords and Firebase credentials should not be exposed in repository.	TC-SEC-5 Check .env, service account JSON, and .gitigno re.	Secret files are not committed.	Secrets were moved outside committed source code.	Pas
Software and Data Integrity	FR-14, FR-15	CSV upload should not create duplicate or inconsistent room records.	TC-SEC-6 Upload CSV and check room records.	Duplicate room records are avoided.	Duplicate room handling was added.	Pas

Logging and Monitoring	NFR-10	Deployment issues should be diagnosable through logs.	TC-SEC-7 Review Render/ frontend errors during deployment testing.	Logs identify failed requests or backend errors.	Logs helped identify deployment/ API issues.	Pas
------------------------	--------	---	---	--	--	-----

7. OWASP Security Test Case Details

Test Case ID	OWASP Area	Steps	Expected Result	Actual Result	Status
TC-SEC-1	Broken Access Control	Attempt to access admin upload behavior without a valid login token.	Backend does not process the upload.	Backend rejected unauthorized upload.	Pass
TC-SEC-2	Identification and Authentication Failures	Submit a CSV upload request with missing or invalid Firebase bearer token.	Backend returns unauthorized response.	Backend rejected the request.	Pass
TC-SEC-3	Injection	Review room search backend code and test search inputs.	User inputs are passed as query parameters/ parameterized values, not raw SQL string concatenation.	Backend used parameterized values for query inputs.	Pass
TC-SEC-4	Security Misconfiguration	Verify CORS origins and deployment environment variables.	Local and deployed frontend origins are allowed; secrets are configured outside code.	CORS and environment variables were configured.	Pass
TC-SEC-5	Sensitive Data Exposure	Check repository	Sensitive files are not committed.	Sensitive values were excluded	Pass

		and .gitignore for .env and Firebase service account files.		from GitHub.	
TC-SEC-6	Software/Data Integrity	Upload semester data and inspect room records.	Duplicate room records are avoided when the same room appears multiple times in the CSV.	Duplicate room prevention was implemented.	Pass
TC-SEC-7	Logging and Monitoring	Review browser console and Render logs during deployment testing.	Errors can be identified and traced to frontend/backend issues.	Logs were used to diagnose CORS, API URL, and backend timeout issues.	Pass

8. Requirement Coverage Summary

Requirement Group	Covered by Test Cases
Stakeholder Requirements	SR-1 through SR-10
Functional Requirements	FR-1 through FR-18
Security Requirements	SEC-1 through SEC-8
Use Cases	UC-1 through UC-5
OWASP-Informed Tests	Broken Access Control, Authentication Failures, Injection, Security Misconfiguration, Sensitive Data Exposure, Data Integrity, Logging/Monitoring